Bonnes pratiques informatiques

Explications et exemples concrets

Made with GAMMA

Pratique n°1 : Ne pas cliquer sur les liens / emails / SMS douteux

Cette pratique vise à prévenir les attaques de phishing et les malwares. Les cybercriminels envoient des messages frauduleux qui semblent provenir de sources fiables pour vous inciter à cliquer sur des liens malveillants ou à télécharger des fichiers infectés.

Exemples concrets :

- Un email prétendant venir de votre banque vous demandant de "vérifier votre compte" avec un lien suspect
- Un SMS d'une plateforme de livraison avec un lien pour "suivre votre colis"
- Un message WhatsApp d'un "ami" avec un lien raccourci douteux
- Un email d'une entreprise connue avec des fautes d'orthographe et une adresse email suspecte

Conseil :

Vérifiez toujours l'adresse email de l'expéditeur, passez votre souris sur les liens pour voir l'URL réelle, et contactez directement l'entreprise si vous avez un doute.

Made with GAMMA

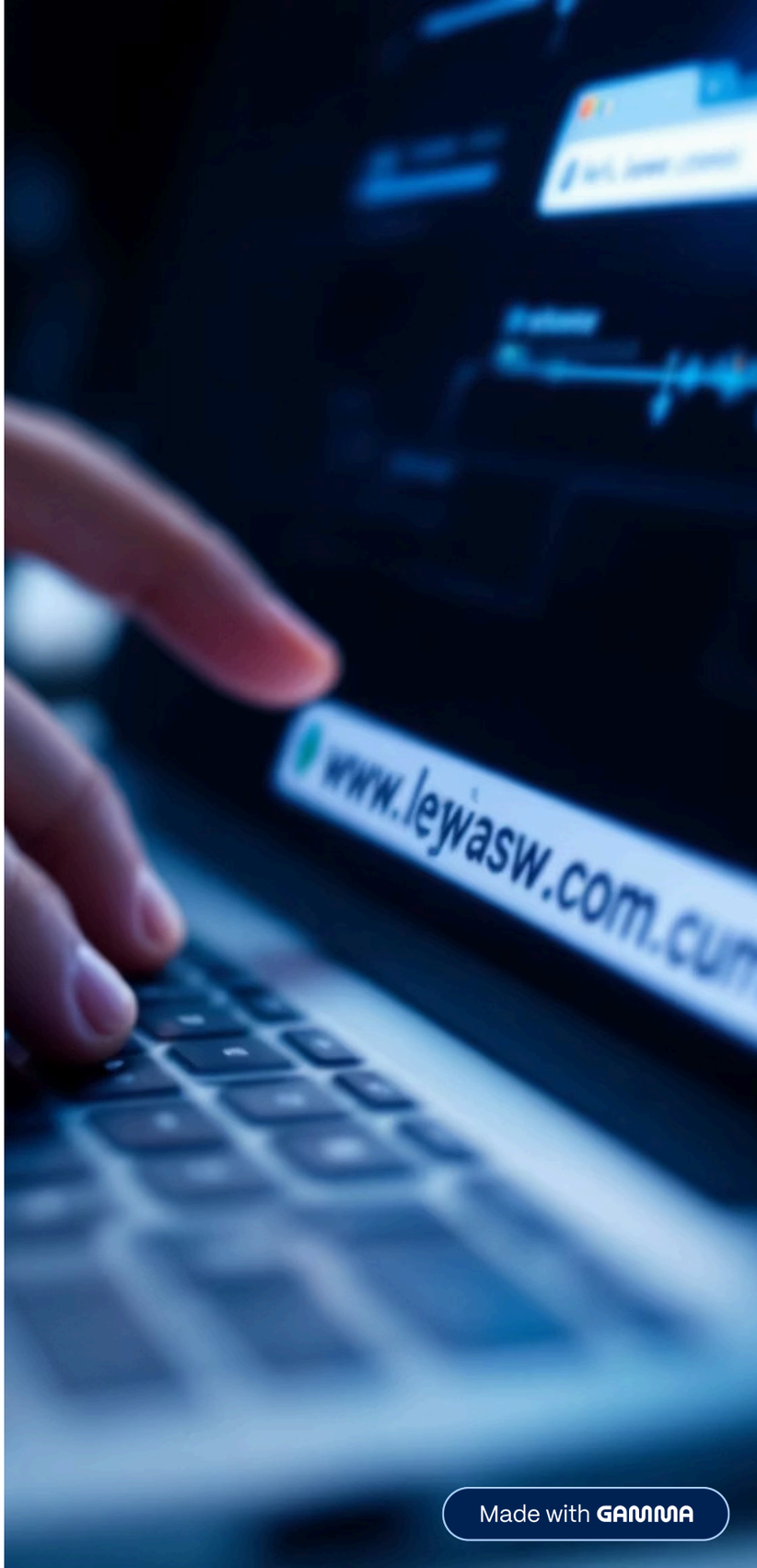
Pratique n°2 : Aller directement sur le site souhaité lors d'une alerte sur votre compte (ne pas utiliser le mail)

Explication : Lorsque vous recevez une alerte concernant votre compte, les cybercriminels créent souvent des faux emails ou SMS vous incitant à cliquer sur un lien qui vous mène vers un faux site. En allant directement sur le site officiel via votre navigateur, vous évitez ces pièges.

Exemples concrets :

- Vous recevez un email disant "Votre compte Amazon a été compromis, cliquez ici" → Allez directement sur amazon.fr au lieu de cliquer
- Un SMS de PayPal vous demandant de confirmer votre identité → Ouvrez PayPal directement dans votre navigateur
- Une alerte de votre banque par email → Appelez votre banque ou accédez à votre compte via l'application officielle
- Un message LinkedIn vous demandant de vérifier votre compte → Connectez-vous directement sur linkedin.com

Conseil : Marquez les sites importants en favoris pour y accéder rapidement sans passer par les emails.



Made with GAMMA

Pratique n°3 : Ne pas acheter sur des sites internet dont on n'a pas vérifié la véracité

Explication : Les faux sites de commerce électronique sont conçus pour voler vos données bancaires et personnelles. Avant d'acheter, il est crucial de vérifier la légitimité du site.

Exemples concrets :

- Un site proposant des produits de marque à 90% de réduction avec des avis suspects
- Un site sans certificat HTTPS (pas de cadenas dans la barre d'adresse)
- Un site avec une adresse email de contact gratuite (gmail, hotmail) au lieu d'un domaine professionnel
- Un site avec des fautes d'orthographe, des images de mauvaise qualité ou un design peu professionnel
- Un site sans mentions légales, conditions générales ou politique de confidentialité

Conseil : Vérifiez les avis sur Google, consultez les forums de consommateurs, vérifiez que le site a un certificat SSL (https://), et utilisez des services de paiement sécurisés comme PayPal.

Made with GAMMA

Pratique n°4 : Avoir un mot de passe robuste

Explication : Un mot de passe robuste est votre première ligne de défense contre les accès non autorisés. Les mots de passe faibles peuvent être devinés ou cassés rapidement par des outils informatiques.

Exemples concrets de mauvais mots de passe :

- "123456" ou "password"
- "azerty" ou "qwerty"
- Votre date de naissance ou votre nom
- "Admin123" ou des mots du dictionnaire

Exemples de bons mots de passe :

- "7xK#mP2$vL9@nQ" (mélange de majuscules, minuscules, chiffres et caractères spéciaux)
- "Soleil2024!Bleu" (phrase mémorisable avec majuscules et chiffres)
- "CaféParis42&Étoile" (combinaison personnelle complexe)

Caractéristiques d'un bon mot de passe :

- Au moins 12 caractères
- Mélange de majuscules, minuscules, chiffres et caractères spéciaux
- Pas de mots du dictionnaire ou d'informations personnelles
- Unique pour chaque compte important

Conseil : Utilisez un gestionnaire de mots de passe comme Bitwarden ou 1Password pour générer et stocker vos mots de passe de manière sécurisée.

Made with GAMMA

Pratique n°5 : Ne pas donner ses identifiants à autrui

Explication : Vos identifiants (nom d'utilisateur et mot de passe) sont personnels et confidentiels. Les partager expose vos comptes au risque d'accès non autorisé, de vol de données et de fraude.

Exemples concrets de situations à éviter :

- Donner votre mot de passe à un collègue "juste pour vérifier quelque chose"
- Partager vos identifiants de banque avec un ami ou un membre de la famille
- Communiquer vos codes d'accès à un prestataire informatique sans protocole de sécurité
- Écrire vos mots de passe sur un post-it visible sur votre bureau
- Donner vos identifiants à quelqu'un qui prétend être du support technique

Situations légitimes où partager est nécessaire :

- Utiliser un gestionnaire de mots de passe partagé en entreprise avec contrôle d'accès
- Donner accès via des outils d'administration sécurisés (délégation de droits)
- Partager via des canaux chiffrés avec authentification à deux facteurs

Conseil : Si quelqu'un a besoin d'accéder à votre compte, créez un compte séparé avec des droits limités ou utilisez des outils de partage sécurisé. Changez immédiatement votre mot de passe si vous pensez qu'il a été compromis.

Made with GAMMA

Pratique n°6 : Changer de mot de passe régulièrement

Explication : Changer régulièrement vos mots de passe réduit le risque qu'un mot de passe compromis soit utilisé longtemps. Cela limite aussi les dégâts en cas de fuite de données.

Exemples concrets :

- Vous découvrez qu'un site où vous aviez un compte a été piraté → Changez immédiatement votre mot de passe
- Vous avez utilisé le même mot de passe sur plusieurs sites → Changez-le partout
- Vous avez partagé votre mot de passe avec quelqu'un qui a quitté l'entreprise → Changez-le
- Vous avez saisi votre mot de passe sur un ordinateur public → Changez-le dès que possible
- Vous n'avez pas changé votre mot de passe depuis plus de 6 mois → C'est le moment

Fréquence recommandée :

- Comptes sensibles (email, banque, réseaux sociaux) : tous les 3 mois
- Comptes professionnels : selon la politique de l'entreprise (généralement 6 mois)
- Autres comptes : au moins une fois par an

Conseil : Utilisez un gestionnaire de mots de passe pour générer des mots de passe forts et différents à chaque changement. Notez la date du dernier changement pour suivre vos mises à jour.

Made with GAMMA

Pratique n°7 : Avoir un mot de passe différent pour chaque plateforme

Explication : Utiliser le même mot de passe partout est extrêmement dangereux. Si un site est piraté, les cybercriminels peuvent utiliser ce mot de passe pour accéder à tous vos autres comptes.

Exemples concrets de risques :

- Vous utilisez "MonMotDePasse123" partout. LinkedIn est piraté → Les hackers accèdent à votre email, banque, réseaux sociaux
- Un site mineur est compromis → Vos comptes importants (email, banque) sont maintenant vulnérables
- Vous réutilisez le même mot de passe sur 10 sites → Un seul piratage compromet tous vos comptes
- Vous utilisez une variation simple (MonMotDePasse123, MonMotDePasse124) → Les hackers peuvent deviner les autres

Exemples de bonne pratique :

- Email : "7xK#mP2$vL9@nQ"
- Banque : "Soleil2024!Bleu"
- LinkedIn : "CaféParis42&Étoile"
- Amazon : "Montagne#Rivière88"
- Netflix : "Étoile$Lune2024"

Conseil : Utilisez un gestionnaire de mots de passe (Bitwarden, 1Password, LastPass) pour générer et stocker automatiquement des mots de passe uniques pour chaque site. Vous n'aurez à mémoriser que le mot de passe principal du gestionnaire.

Made with GAMMA

Pratique n°8 : Utiliser la 2FA (Authentification à Deux Facteurs)

Explication : La 2FA ajoute une couche de sécurité supplémentaire. Même si quelqu'un connaît votre mot de passe, il ne peut pas accéder à votre compte sans le deuxième facteur d'authentification.

Types de 2FA :

- SMS : Un code est envoyé par SMS à votre téléphone
- Email : Un code est envoyé à votre adresse email
- Application d'authentification : Vous générez un code avec une app (Google Authenticator, Authy, Microsoft Authenticator)
- Clé de sécurité : Une clé USB ou NFC physique (YubiKey, Titan)
- Biométrie : Empreinte digitale ou reconnaissance faciale

Exemples concrets :

- Vous vous connectez à Gmail → Vous entrez votre mot de passe → Google vous demande un code reçu par SMS → Vous entrez le code
- Quelqu'un vole votre mot de passe LinkedIn → Il essaie de se connecter → LinkedIn demande un code d'authentification → Sans votre téléphone, il ne peut pas accéder
- Vous activez 2FA sur votre compte bancaire → Chaque transaction sensible demande une confirmation supplémentaire
- Vous utilisez une clé de sécurité sur votre email → Même les hackers avec votre mot de passe ne peuvent pas accéder

Conseil : Activez la 2FA sur tous vos comptes importants (email, banque, réseaux sociaux, travail). Préférez les applications d'authentification ou les clés de sécurité aux SMS, qui peuvent être interceptés.

Made with GAMMA

Pratique n°9 : Faire des sauvegardes régulières

Explication : Les sauvegardes protègent vos données contre les pertes accidentelles, les ransomwares et les défaillances matérielles. Une bonne stratégie de sauvegarde suit la règle 3-2-1.

3 copies de vos données

(original + 2 sauvegardes)

2 supports différents

(disque dur externe + cloud)

1 copie hors site

(stockage cloud ou chez un ami)

Exemples concrets :

- Votre ordinateur tombe en panne → Vous avez une sauvegarde sur un disque externe
- Un ransomware chiffre vos fichiers → Vous restaurez à partir d'une sauvegarde antérieure
- Vous supprimez accidentellement des photos importantes → Vous les récupérez depuis le cloud
- Votre maison brûle → Vous avez une copie de vos données dans le cloud
- Vous perdez votre téléphone → Vos contacts et photos sont sauvegardés dans le cloud

Outils de sauvegarde :

Cloud

Google Drive, OneDrive, Dropbox, Nextcloud

Disque externe

Seagate, WD, Toshiba

Sauvegarde automatique

Backblaze, Carbonite, Acronis

Fréquence recommandée :

- Données critiques : quotidienne
- Données importantes : hebdomadaire
- Autres données : mensuel

Conseil : Automatisez vos sauvegardes pour ne pas les oublier. Testez régulièrement que vous pouvez restaurer vos données.

Made with GAMMA

Pratique n°10 : Ne pas se connecter à des réseaux publics

Explication : Les réseaux WiFi publics (cafés, aéroports, hôtels) ne sont pas sécurisés. Les cybercriminels peuvent intercepter vos données, voler vos identifiants ou installer des malwares sur votre appareil.

Risques des réseaux publics :

- Interception de données : Quelqu'un peut voir vos emails, messages, données bancaires
- Vol d'identifiants : Vos mots de passe peuvent être capturés
- Faux réseaux : Un hacker crée un faux WiFi "CaféWiFi" pour piéger les utilisateurs
- Malwares : Votre appareil peut être infecté par des virus
- Man-in-the-middle : Un attaquant se place entre vous et le serveur pour intercepter les données

Exemples concrets :

- Vous vous connectez au WiFi d'un café et consultez votre email → Un hacker capture votre mot de passe
- Vous faites un virement bancaire sur le WiFi de l'aéroport → Quelqu'un intercepte vos données bancaires
- Vous vous connectez à "AirportWiFi_Free" → C'est un faux réseau créé par un hacker
- Vous téléchargez un fichier sur le WiFi public → Le fichier contient un malware
- Vous vous connectez à un réseau sans mot de passe → N'importe qui peut voir votre trafic

Solutions sécurisées :

- Utiliser un VPN (Virtual Private Network) : ExpressVPN, NordVPN, ProtonVPN
- Utiliser le hotspot de votre téléphone (données mobiles)
- Attendre d'être sur un réseau sécurisé pour les opérations sensibles
- Désactiver le WiFi et le Bluetooth quand vous ne les utilisez pas
- Ne pas accéder à des comptes sensibles (banque, email) sur WiFi public

Conseil : Installez un VPN fiable sur tous vos appareils. Un bon VPN chiffre tout votre trafic, même sur des réseaux publics.

Made with GAMMA

Pratique n°11 : Vérifier le bon fonctionnement des antivirus et firewall

Explication : Un antivirus et un firewall sont essentiels pour protéger votre ordinateur contre les malwares, les virus et les accès non autorisés. Ils doivent être à jour et activés en permanence.

Antivirus

Détecte et supprime les malwares, virus, trojans

Firewall

Contrôle le trafic réseau entrant et sortant, bloque les connexions non autorisées

Exemples concrets :

- Vous téléchargez un fichier infecté → L'antivirus le détecte et le supprime avant qu'il ne s'exécute
- Un hacker essaie d'accéder à votre ordinateur → Le firewall bloque la connexion
- Vous visitez un site malveillant → L'antivirus vous avertit et vous empêche d'accéder
- Un malware essaie de se connecter à un serveur distant → Le firewall bloque la connexion
- Votre antivirus n'a pas été mis à jour depuis 6 mois → Il ne peut pas détecter les nouveaux virus

Antivirus recommandés :

Windows Defender

(gratuit, intégré à Windows)

Kaspersky, Norton, McAfee

(payants, très complets)

Avast, AVG

(gratuit avec version payante)

Vérifications régulières :

Vérifier que l'antivirus est activé et à jour

Faire des scans complets mensuels

Vérifier que le firewall est activé

Mettre à jour Windows et les logiciels régulièrement

Consulter les logs pour voir les menaces détectées

Conseil : Activez les mises à jour automatiques pour votre antivirus et votre système d'exploitation. Faites un scan complet au moins une fois par mois.

Made with GAMMA

Pratique n°12 : Contact d'un référent informatique

Explication : Avoir un point de contact informatique permet de signaler rapidement les problèmes de sécurité, de recevoir du support technique et de mettre en place les bonnes pratiques dans l'organisation.

Rôles du référent informatique :

Supporter les utilisateurs

En cas de problème technique

Signaler les incidents

Incidents de sécurité

Mettre à jour les systèmes

Et logiciels

Former les utilisateurs

Aux bonnes pratiques

Gérer les accès

Et les droits

Maintenir la sécurité

Du réseau

Exemples concrets :

- Vous recevez un email suspect → Vous le signalez au référent informatique
- Votre ordinateur est lent ou affiche des messages bizarres → Vous contactez le référent
- Vous avez oublié votre mot de passe → Le référent vous aide à le réinitialiser
- Vous avez besoin d'accéder à un nouveau logiciel → Le référent configure l'accès
- Vous avez cliqué sur un lien malveillant → Vous le signalez immédiatement au référent
- Vous découvrez une faille de sécurité → Vous la rapportez au référent

Informations à avoir :

Nom et coordonnées

Du référent informatique

Numéro de téléphone ou email

Pour les urgences

Procédure de signalement

Des incidents

Horaires de disponibilité

Processus de demande

D'accès ou de support

Conseil : Établissez une relation de confiance avec votre référent informatique. Signalez rapidement tout problème ou comportement suspect. Ne tentez pas de résoudre seul les problèmes de sécurité.

Made with GAMMA

Pratique n°13 : Cartographier le réseau interne avec tous les équipements

Explication : Connaître tous les équipements connectés au réseau permet de détecter les appareils non autorisés, de gérer les accès et de maintenir la sécurité du réseau.

Éléments à cartographier :

- Ordinateurs de bureau et portables
- Serveurs
- Imprimantes et scanners
- Routeurs et commutateurs
- Téléphones IP
- Caméras de surveillance
- Appareils IoT (objets connectés)
- Appareils mobiles (téléphones, tablettes)

Informations à documenter :

- Adresse IP de chaque appareil
- Adresse MAC (identifiant unique)
- Nom de l'appareil
- Propriétaire ou utilisateur
- Localisation physique
- Système d'exploitation ou type d'appareil
- Logiciels installés
- Date d'acquisition
- État de sécurité (antivirus, pare-feu, mises à jour)

Exemples concrets :

- Vous découvrez un appareil inconnu sur le réseau → Vous pouvez l'identifier et le bloquer
- Un ordinateur est infecté par un malware → Vous savez quels autres appareils il a contactés
- Vous devez mettre à jour tous les serveurs → Vous avez une liste complète
- Un employé quitte l'entreprise → Vous savez quels appareils lui appartenaient
- Vous devez vérifier la conformité de sécurité → Vous avez un inventaire complet

Outils de cartographie :

Nmap

Scanner de réseau gratuit

Angry IP Scanner

Outil de scan d'adresses IP

SolarWinds

Solution professionnelle de gestion de réseau

Zabbix

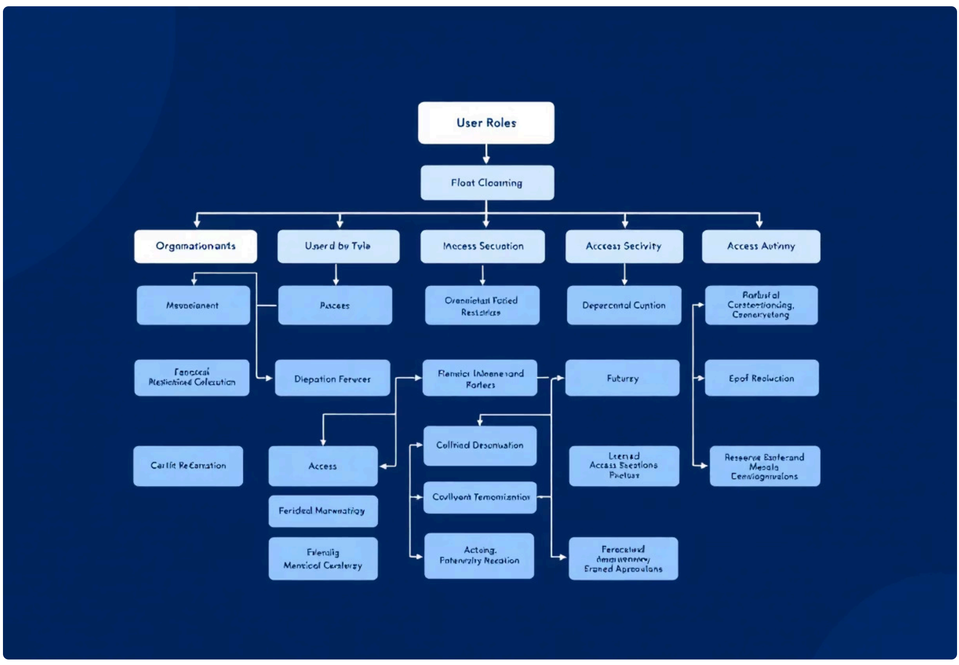
Monitoring et cartographie de réseau

Conseil : Mettez à jour régulièrement votre cartographie (au moins trimestriellement). Documentez tout nouvel équipement connecté au réseau.

Made with GAMMA

Pratique n°14 : Avoir un organigramme des utilisateurs et de leurs droits

Explication : Documenter qui a accès à quoi est essentiel pour la sécurité. Cela permet de s'assurer que chaque utilisateur n'a que les droits nécessaires à son travail (principe du moindre privilège).



Informations à documenter :

- Nom et prénom de chaque utilisateur
- Poste et département
- Adresse email professionnelle
- Numéro de téléphone
- Date d'embauche et de départ
- Droits d'accès aux systèmes
- Droits d'accès aux fichiers et dossiers
- Droits d'accès aux applications
- Droits administrateur (si applicable)
- Appareils assignés (ordinateur, téléphone, etc.)

Exemples concrets :

- Un employé quitte l'entreprise → Vous savez immédiatement quels accès révoquer
- Un nouvel employé arrive → Vous savez exactement quels droits lui donner
- Un employé change de poste → Vous mettez à jour ses droits d'accès
- Vous découvrez un accès non autorisé → Vous pouvez identifier qui l'a fait
- Un compte est compromis → Vous savez quels systèmes ont été potentiellement affectés
- Vous devez vérifier la conformité → Vous avez un audit complet des droits

Principes de gestion des droits :

Moindre privilège

Chaque utilisateur n'a que les droits nécessaires

Séparation des tâches

Les tâches sensibles sont réparties entre plusieurs personnes

Révocation rapide

Les droits sont révoqués immédiatement au départ

Audit régulier

Vérifier que les droits sont toujours appropriés

Documentation

Tout changement de droits est documenté

Outils de gestion :

Active Directory

(Microsoft) : Gestion centralisée des utilisateurs et droits

LDAP

Protocole standard de gestion d'annuaire

Okta

Gestion des identités et accès

Tableau Excel ou base de données

Pour les petites organisations

Conseil : Effectuez un audit des droits au moins une fois par an. Révoquez immédiatement les droits des employés qui quittent l'entreprise.

Made with GAMMA

Pratique n°15 : Mettre à jour les équipements

Explication : Les mises à jour de sécurité corrigent les failles qui pourraient être exploitées par les cybercriminels. Ne pas mettre à jour expose vos systèmes à des risques graves.

Types de mises à jour :

Mises à jour de sécurité

Corrigent les failles de sécurité

Mises à jour de stabilité

Améliorent les performances et la fiabilité

Mises à jour de fonctionnalités

Ajoutent de nouvelles fonctionnalités

Correctifs critiques

Corrigent les bugs graves

Équipements à mettre à jour :

- Systèmes d'exploitation (Windows, macOS, Linux)
- Navigateurs web (Chrome, Firefox, Edge)
- Logiciels (Office, Adobe, antivirus)
- Routeurs et commutateurs
- Serveurs
- Téléphones et tablettes
- Imprimantes et autres appareils connectés

Exemples concrets :

- Une faille critique est découverte dans Windows → Vous installez la mise à jour immédiatement
- Votre navigateur n'a pas été mis à jour depuis 6 mois → Il est vulnérable aux attaques
- Un serveur n'a pas reçu de mise à jour depuis 2 ans → Il contient des dizaines de failles
- Vous ignorez une mise à jour de sécurité → Votre ordinateur est infecté par un ransomware
- Vous mettez à jour régulièrement → Vous êtes protégé contre les menaces connues

Fréquence recommandée :

01

Mises à jour critiques

Immédiatement

02

Mises à jour de sécurité

Hebdomadaire ou mensuel

03

Autres mises à jour

Mensuellement ou trimestriellement

Bonnes pratiques :

Activez les mises à jour automatiques

Testez les mises à jour

Sur un système de test avant de les déployer en production

Planifiez les mises à jour

Pendant les heures creuses

Documentez toutes les mises à jour

Effectuées

Gardez une sauvegarde

Avant les mises à jour importantes

Conseil : Activez les mises à jour automatiques sur tous vos appareils. Redémarrez régulièrement vos systèmes pour appliquer les mises à jour en attente.

Made with GAMMA

Pratique n°16 : Installer des VLAN et des firewalls pour segmenter les équipements, les autorisations et les accès

Explication : La segmentation du réseau isole les équipements sensibles et limite la propagation des menaces. Un VLAN (Virtual Local Area Network) crée des réseaux virtuels séparés, et un firewall contrôle le trafic entre eux.

Avantages de la segmentation :

- **Isolation des données sensibles**
- **Limitation de la propagation des malwares**
- **Contrôle granulaire des accès**
- **Amélioration des performances**
- **Conformité réglementaire (RGPD, PCI-DSS)**

Types de VLAN à créer :

VLAN administratif
Pour les administrateurs IT

VLAN serveurs
Pour les serveurs critiques

VLAN utilisateurs
Pour les ordinateurs de bureau

VLAN invités
Pour les visiteurs et appareils externes

VLAN IoT
Pour les appareils connectés (imprimantes, caméras)

VLAN données sensibles
Pour les données financières ou confidentielles

Exemples concrets :

- Un ordinateur utilisateur est infecté par un malware → Le firewall empêche le malware d'accéder aux serveurs
- Un visiteur se connecte au WiFi invité → Il ne peut pas accéder aux données de l'entreprise
- Une imprimante est compromise → Elle ne peut pas accéder aux serveurs de données
- Un employé du département RH accède à des données sensibles → Le firewall autorise cet accès
- Un attaquant externe essaie d'accéder au réseau → Le firewall bloque la connexion

Configuration du firewall :

- **Règles d'entrée**
  Contrôlent le trafic entrant
- **Règles de sortie**
  Contrôlent le trafic sortant
- **Listes blanches**
  Autorisent uniquement le trafic spécifié
- **Listes noires**
  Bloquent le trafic spécifié
- **Inspection approfondie des paquets**
  Analyse le contenu du trafic

Outils de segmentation :

Cisco Catalyst
Commutateurs gérés avec support VLAN

Fortinet FortiGate
Firewall professionnel

Palo Alto Networks
Firewall de nouvelle génération

pfSense
Firewall open-source gratuit

Ubiquiti UniFi
Solution complète de réseau

Conseil : Commencez par segmenter les données sensibles et les serveurs critiques. Testez les règles de firewall avant de les déployer en production. Documentez toutes les règles de segmentation.

Made with GAMMA

Pratique n°17 : Former les nouveaux arrivants aux bonnes pratiques de l'entreprise

Explication : La formation est essentielle pour que tous les employés comprennent les risques de sécurité et adoptent les bonnes pratiques. Les erreurs humaines sont la cause de la plupart des incidents de sécurité.

Sujets de formation à couvrir :

- **Politique de sécurité de l'entreprise**
- **Gestion des mots de passe**
- **Reconnaissance du phishing et des emails suspects**
- **Utilisation sécurisée d'Internet et du WiFi**
- **Gestion des données sensibles**
- **Signalement des incidents de sécurité**
- **Utilisation des VPN et des outils de chiffrement**
- **Sécurité des appareils mobiles**
- **Conformité réglementaire (RGPD, etc.)**

Exemples concrets :

- Un nouvel employé reçoit une formation sur le phishing → Il reconnaît un email suspect et le signale
- Un employé apprend à utiliser un VPN → Il ne se connecte plus au WiFi public sans protection
- Un employé comprend l'importance des mots de passe forts → Il crée un mot de passe robuste
- Un employé sait comment signaler un incident → Il contacte immédiatement le référent IT
- Un employé comprend la politique de données → Il ne partage pas les données sensibles

Méthodes de formation :

Formation en personne
Réunion avec tous les nouveaux arrivants

Formation en ligne
Modules e-learning interactifs

Documentation écrite
Guide de sécurité à consulter

Vidéos
Tutoriels visuels sur les bonnes pratiques

Simulations
Exercices pratiques (test de phishing, etc.)

Certification
Test pour vérifier la compréhension

Fréquence de formation :

Formation initiale
Lors de l'arrivée (obligatoire)

Formation annuelle
Rappel des bonnes pratiques

Formation spécialisée
Selon le rôle (administrateurs, RH, etc.)

Formation d'urgence
Après un incident ou une nouvelle menace

Conseil : Rendez la formation engageante et pertinente. Utilisez des exemples concrets et des cas réels. Évaluez régulièrement la compréhension et l'adoption des bonnes pratiques.

Made with GAMMA

Pratique n°18 : Faire des réunions sécurité pour faire remonter les nouvelles menaces, remonter des problèmes de chacun et voir les idées d'améliorations

Explication : Les réunions de sécurité régulières créent une culture de sécurité, permettent de partager les menaces émergentes et d'améliorer continuellement les pratiques de l'organisation.

Objectifs des réunions de sécurité :

- **Partager les nouvelles menaces et vulnérabilités**
- **Discuter des incidents récents et des leçons apprises**
- **Recueillir les problèmes et préoccupations des employés**
- **Identifier les opportunités d'amélioration**
- **Renforcer la sensibilisation à la sécurité**
- **Créer une culture de sécurité collaborative**

Sujets à couvrir :

- **Nouvelles menaces découvertes** (ransomwares, phishing, etc.)
- **Incidents de sécurité survenus dans l'entreprise**
- **Mises à jour de sécurité et correctifs appliqués**
- **Changements de politique de sécurité**
- **Résultats des audits de sécurité**
- **Feedback des employés sur les outils et processus**
- **Idées d'amélioration proposées par les employés**
- **Conformité réglementaire et audits externes**

Exemples concrets :

- Une nouvelle vague de phishing est détectée → Vous en discutez en réunion et envoyez une alerte
- Un employé a cliqué sur un lien malveillant → Vous en discutez pour apprendre de l'incident
- Un employé propose une meilleure façon de gérer les mots de passe → Vous l'implémentez
- Une faille de sécurité est découverte → Vous la discutez et planifiez la correction
- Un employé signale un problème d'accès → Vous le résolvez et documentez la solution

Fréquence et format :

1. **Réunions mensuelles**
   Pour les petites organisations
2. **Réunions trimestrielles**
   Pour les organisations moyennes
3. **Réunions hebdomadaires**
   Pour les équipes IT
4. **Format**
   En personne, vidéoconférence ou hybride
5. **Durée**
   30 à 60 minutes
6. **Participants**
   Référent IT, responsables de département, représentants des employés

Agenda type :

01
Nouvelles menaces et vulnérabilités
(10 min)

02
Incidents survenus et leçons apprises
(15 min)

03
Mises à jour de sécurité et changements
(10 min)

04
Feedback et problèmes des employés
(15 min)

05
Idées d'amélioration
(10 min)

06
Actions et suivi
(10 min)

Conseil : Rendez les réunions interactives et inclusives. Encouragez les employés à partager leurs préoccupations sans crainte. Documentez les décisions et les actions à suivre.

Made with GAMMA

Pratique n°19 : Se renseigner sur ses prestataires

Explication : Les prestataires externes (fournisseurs de services, consultants, sous-traitants) ont accès à vos systèmes et données. Il est crucial de vérifier leur sécurité et leur fiabilité avant de les engager.

Critères d'évaluation des prestataires :

Certifications de sécurité (ISO 27001, SOC 2, etc.)	**Politique de sécurité documentée**	**Antécédents de sécurité** (incidents passés)
Assurance responsabilité civile	**Conformité réglementaire** (RGPD, etc.)	**Références et clients existants**
Processus de gestion des données	**Plan de continuité et de récupération**	**Audit de sécurité régulier**

Questions à poser aux prestataires :

- → **Avez-vous une certification ISO 27001 ou SOC 2 ?**
- → **Comment gérez-vous la sécurité des données ?**
- → **Avez-vous eu des incidents de sécurité ? Si oui, comment les avez-vous gérés ?**
- → **Où sont stockées les données (localisation géographique) ?**
- → **Qui a accès aux données et comment est-ce contrôlé ?**
- → **Avez-vous une assurance responsabilité civile ?**
- → **Pouvez-vous fournir des références de clients ?**
- → **Avez-vous un plan de continuité en cas de sinistre ?**

Exemples concrets :

- Vous engagez un consultant IT → Vous vérifiez ses certifications et ses antécédents
- Vous choisissez un fournisseur cloud → Vous vérifiez sa conformité RGPD et ses certifications
- Un prestataire a accès à vos données sensibles → Vous signez un accord de confidentialité
- Un fournisseur subit une cyberattaque → Vous évaluez l'impact sur votre organisation
- Vous changez de prestataire → Vous vérifiez que les données sont bien supprimées

Contrats à mettre en place :

Accord de confidentialité (NDA)	**Accord de niveau de service (SLA)**
Accord de traitement des données (DPA)	**Clause de sécurité des données**
Clause de notification des incidents	**Clause de droit d'audit**

Conseil : Effectuez un audit de sécurité régulier de vos prestataires. Incluez des clauses de sécurité dans tous les contrats. Maintenez une liste à jour de tous les prestataires et de leurs accès.

Made with GAMMA

Pratique n°20 : Garder ses appareils sous surveillance et/ou les verrouiller

Explication : Les appareils physiques (ordinateurs, téléphones, tablettes) peuvent être volés ou compromis. Les verrouiller et les surveiller réduit les risques de vol de données et d'accès non autorisé.

Mesures de sécurité physique :

Verrouillage des appareils
Mot de passe, PIN, biométrie

Chiffrement du disque dur
BitLocker, FileVault, LUKS

Localisation des appareils
GPS, Find My Device

Gestion des appareils mobiles (MDM)
Contrôle centralisé

Surveillance des appareils
Antivirus, détection d'intrusion

Destruction sécurisée
Suppression des données avant recyclage

Exemples concrets :

- Vous laissez votre ordinateur déverrouillé → Un collègue peut accéder à vos données
- Votre téléphone est volé → Sans verrouillage, le voleur accède à vos données
- Votre disque dur n'est pas chiffré → Si l'ordinateur est volé, les données peuvent être récupérées
- Vous activez Find My Device → Vous pouvez localiser et effacer votre téléphone perdu
- Vous installez un MDM → Vous pouvez effacer les données d'un appareil volé

Bonnes pratiques :

→ **Verrouiller votre appareil quand vous vous absentez**

→ **Utiliser un mot de passe fort pour déverrouiller**

→ **Activer le chiffrement du disque dur**

→ **Activer la localisation sur les appareils mobiles**

→ **Installer un antivirus et un pare-feu**

→ **Mettre à jour régulièrement le système d'exploitation**

→ **Désactiver les ports USB non utilisés**

→ **Utiliser un câble de sécurité pour les ordinateurs portables**

→ **Garder les appareils en vue ou dans un endroit sécurisé**

Outils de surveillance et de verrouillage :

Windows
BitLocker, Windows Defender, Find My Device

macOS
FileVault, Find My Mac

iOS
Find My iPhone, Face ID, Touch ID

Android
Find My Mobile, Google Find My Device

MDM
Microsoft Intune, Jamf, MobileIron

Antivirus
Kaspersky, Norton, McAfee

Conseil : Activez le verrouillage automatique après 5-10 minutes d'inactivité. Utilisez la biométrie (empreinte digitale, reconnaissance faciale) pour plus de sécurité. Signalez immédiatement tout appareil perdu ou volé.

Made with GAMMA